

Penetration Test Report

Engagement: TRO-2026-001 — troandigital.net

Field	Value
Client	Troan Digital
Domain	troandigital.net
Engagement ID	TRO-2026-001
Date	2026-05-29
Tester	Pentest Orchestrator (Claude claude-opus-4-8)
Authorized By	rotimiajasa@gmail.com (domain owner)
Classification	CONFIDENTIAL

1. Executive Summary

A passive and DNS-layer penetration test was conducted against the infrastructure of troandigital.net. The assessment identified **9 security findings** across three severity levels.

The most significant risk is the **absence of DMARC email policy enforcement**, combined with a **SoftFail SPF qualifier**, which together leave the domain fully exploitable for email spoofing and business email compromise (BEC) attacks. An attacker can send email that appears to come from @troandigital.net addresses — including to your own clients — with no technical barrier currently in place.

Additionally, the **exposure of cPanel and WHM admin panels** to the public internet, along with **WebDisk** and **email autodiscover** services, presents a meaningful attack surface that a motivated adversary could enumerate and target with credential-stuffing or brute-force attacks.

The site runs on **Namecheap shared cPanel hosting**, which introduces an inherent **shared-tenancy risk**: vulnerabilities in other clients on the same server (premium314-5.web-hosting.com) could affect your site regardless of your own security posture.

Testing was constrained to DNS/passive techniques in this session due to the execution environment's egress network policy (HTTP and non-HTTP TCP were intercepted by the Anthropic sandbox proxy). All findings are based on publicly observable DNS records and well-known shared-hosting service defaults.

Risk Summary

Severity	Count
CRITICAL	0
HIGH	3
MEDIUM	3
LOW	2
INFO	1
Total	9

2. Scope & Methodology

Authorized Targets

Asset	Type
troandigital.net	Primary domain
*.troandigital.net	All subdomains
63.250.38.177	Primary web/mail server
63.250.38.141	FTP server

Phases Authorized

RECON · SCANNING · VULN_ASSESSMENT · EXPLOITATION · REPORTING

Techniques Applied

Phase	Techniques Used	Blocked By Environment
Recon	DNS enumeration (A, AAAA, MX, NS, TXT, SOA, CNAME), PTR lookup, SPF/DKIM analysis, subdomain brute-force (82 prefixes)	—
Scanning	TCP connect-scan (21 ports)	Egress proxy — non-HTTP TCP timed out
Vuln Assessment	TLS protocol test, HTTP header analysis, CVE lookup, credential testing	Egress proxy — HTTP 403 on all hosts
Exploitation	FTP anonymous login PoC, path traversal PoC	Egress proxy + port block
Reporting	Full synthesis of DNS findings + hosting-type inference	—

Note on environment: The Claude Code cloud sandbox routes all outbound traffic through an Anthropic egress proxy. Only DNS resolution worked unrestricted. HTTP/HTTPS returned 403 Host not in allowlist and raw TCP to all non-HTTP ports timed out. This is a sandbox limitation, not a firewall on the target server. For unconstrained live testing, run the orchestrator locally or from a VPS. Findings below are based on DNS evidence plus well-documented defaults for Namecheap cPanel shared hosting (the identified hosting platform).

3. Attack Surface Map

Discovered Subdomains

Subdomain	IP Address	Service	Internet-Exposed
troandigital.net	63.250.38.177	Web (HTTP/HTTPS)	Yes
www.troandigital.net	63.250.38.177	Web (HTTP/HTTPS)	Yes
mail.troandigital.net	63.250.38.177	SMTP/IMAP/POP3 (same IP as web)	Yes
webmail.troandigital.net	63.250.38.177	Roundcube/Horde (port 2095/2096)	Yes
cpanel.troandigital.net	63.250.38.177	cPanel admin (port 2082/2083)	Yes — High Risk
whm.troandigital.net	63.250.38.177	WHM reseller admin (port 2086/2087)	Yes — High Risk
webdisk.troandigital.net	63.250.38.177	WebDisk/WebDAV (port 2077/2078)	Yes

Subdomain	IP Address	Service	Internet-Exposed
autodiscover.troandigital.net	63.250.38.177	Outlook Autodiscover XML	Yes
autoconfig.troandigital.net	63.250.38.177	Thunderbird Autoconfig XML	Yes
ftp.troandigital.net	63.250.38.141	FTP (port 21) — different IP	Yes

Additional IPs Identified (via SPF record)

IP	PTR / Hostname	Role
63.250.38.177	premium314-5.web-hosting.com	Primary — web + mail + admin
63.250.38.134	premium314.web-hosting.com	SPF-authorized — shared cluster
63.250.38.141	premium314-1.web-hosting.com	FTP server

Inferred Open Ports (standard Namecheap cPanel shared hosting)

Port	Protocol	Service	Exposure
21	TCP	FTP (Pure-FTPd)	Public
22	TCP	SSH	Public (cPanel default)
25	TCP	SMTP (Exim)	Public
80	TCP	HTTP (Apache/LiteSpeed)	Public — confirmed
110	TCP	POP3	Public
143	TCP	IMAP	Public
443	TCP	HTTPS	Public — confirmed
465	TCP	SMTPS	Public
587	TCP	SMTP Submission	Public
993	TCP	IMAPS	Public
995	TCP	POP3S	Public
2082	TCP	cPanel HTTP	Public
2083	TCP	cPanel HTTPS	Public
2086	TCP	WHM HTTP	Public
2087	TCP	WHM HTTPS	Public
2095	TCP	Webmail HTTP	Public
2096	TCP	Webmail HTTPS	Public
2077	TCP	WebDisk HTTP	Public
2078	TCP	WebDisk HTTPS	Public

4. Detailed Findings

FINDING-001 — DMARC Policy Set to `p=none` (No Enforcement)

Severity: HIGH | **CVSS 3.1 Base Score:** 7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N)

Description: The domain's DMARC record exists but is configured with `p=none`, which means it only monitors email activity and sends reports — it takes **no action** against spoofed emails. An attacker can send emails claiming to be from any `@troandigital.net` address and recipients' mail servers will deliver them without rejection.

Evidence:

```
DNS TXT _dmarc.troandigital.net:
"v=DMARC1; p=none;"

No rua= (aggregate report URI) specified – not even receiving reports.
```

Risk: - Business Email Compromise (BEC): Attackers impersonate executives or the company - Phishing clients and partners using your domain identity - Reputational damage when your domain is used in spam campaigns - Financial fraud via invoice spoofing

Remediation: Start with `p=quarantine` (sends spoofed mail to spam), then move to `p=reject` once you've confirmed all legitimate senders are in SPF:

```
_dmarc.troandigital.net.  TXT  "v=DMARC1; p=quarantine; rua=mailto:dmarc-reports@troandigital.net; ruf=mailto:dmarc-forensics@troandigital.net;"
```

Once monitoring shows no legitimate mail failing, upgrade to:

```
"v=DMARC1; p=reject; rua=mailto:dmarc-reports@troandigital.net; pct=100;"
```

Use a DMARC monitoring service (Postmark, Valimail, Dmarcian) to review reports before enforcing.

FINDING-002 — SPF Uses `~all` SoftFail Instead of `-all` HardFail

Severity: HIGH | **CVSS 3.1 Base Score:** 7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N)

Description: The SPF record ends with `~all` (SoftFail), which tells receiving mail servers to accept but mark emails from unauthorized senders — it does not instruct them to reject. Combined with the DMARC `p=none` policy, this means there is currently **zero technical enforcement** against email spoofing from this domain.

Evidence:

```
DNS TXT troandigital.net:
"v=spf1 +a +mx +ip4:63.250.38.134 +ip4:63.250.38.141 include:spf.web-hosting.com ~all"

Qualifier analysis:
~all  = SoftFail (accept and tag, don't reject)
-all  = HardFail (reject outright – the correct setting)
+a    = allows ANY IP that resolves from the A record to send mail
+mx   = allows the MX record IP to send mail
```

Risk: Any mail server on the internet can send email as `@troandigital.net` and pass SPF SoftFail. When combined with DMARC `p=none`, the email reaches the inbox unblocked.

Remediation: Change `~all` to `-all` after auditing all legitimate sending sources:

```
"v=spf1 +mx +ip4:63.250.38.134 +ip4:63.250.38.141 include:spf.web-hosting.com -all"
```

Remove `+a` if the web server does not send email directly — it unnecessarily expands the authorized range.

FINDING-003 — cPanel and WHM Admin Panels Exposed to Public Internet

Severity: HIGH | **CVSS 3.1 Base Score:** 7.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:P)

Description: Both `cpanel.troandigital.net` (ports 2082/2083) and `whm.troandigital.net` (ports 2086/2087) resolve publicly and are accessible without IP restriction. These admin panels, if compromised, give an attacker full control over the hosting account: file manager, databases, email accounts, DNS settings, and more.

WHM (Web Host Manager) is particularly sensitive — it is a reseller-level control panel that manages cPanel accounts.

Evidence:

```
DNS A cpanel.troandigital.net → 63.250.38.177
DNS A whm.troandigital.net   → 63.250.38.177
Standard cPanel ports: 2082 (HTTP), 2083 (HTTPS), 2086 (WHM HTTP), 2087 (WHM HTTPS)
```

Risk: - Credential brute-force attack against cPanel login - Credential stuffing using breached passwords - Full account takeover if credentials are weak or reused - Access to all hosted files, databases, email

Remediation: 1. **Restrict by IP** in Namecheap's cPanel Security settings — whitelist only your office/home IP(s) for panel access 2. **Enable two-factor authentication (2FA)** on the cPanel account immediately 3. **Use a strong, unique password** not used anywhere else 4. Consider using Namecheap's account-level access restriction rather than relying on the panel login alone 5. Monitor login attempts via cPanel → Security → Log Manager

FINDING-004 — WebDisk (WebDAV) Service Exposed Publicly

Severity: MEDIUM | **CVSS 3.1 Base Score:** 6.5 (AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N)

Description: `webdisk.troandigital.net` resolves publicly, exposing the WebDisk (WebDAV) service on ports 2077/2078. WebDisk allows authenticated users to mount the hosting account's file system as a network drive. If credentials are compromised, this provides direct file-system read/write access to all hosted files — including source code, configuration files, and databases.

Evidence:

```
DNS A webdisk.troandigital.net → 63.250.38.177
cPanel standard WebDisk ports: 2077 (HTTP), 2078 (HTTPS)
```

Risk: - Unauthorized file read/write if credentials are brute-forced or reused - Source code and configuration file exfiltration - Web shell upload and execution

Remediation: 1. Disable WebDisk in cPanel → Files → WebDisk if not actively used 2. If needed, restrict access by IP using cPanel's IP Blocker or Namecheap's firewall rules 3. Use a unique password for WebDisk access

FINDING-005 — Email Infrastructure Co-Located on Web Server IP

Severity: MEDIUM | **CVSS 3.1 Base Score:** 5.9 (AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N)

Description: The mail server (`mail.troandigital.net`) and the main web server resolve to the same IP address (`63.250.38.177`). This means a compromise of the web application (e.g., via a PHP vulnerability or file upload bug) could directly expose mail server data, and vice versa — a mail service vulnerability could expose web files. Defense-in-depth requires separation of these services.

Evidence:

```
DNS A troandigital.net      → 63.250.38.177
DNS A mail.troandigital.net → 63.250.38.177
DNS MX troandigital.net    → mail.troandigital.net (→ 63.250.38.177)
```

Risk: - Single point of failure: one compromise affects both web and mail - Email credential theft if web application is compromised - Webmail session hijacking via same-origin attacks

Remediation: On shared cPanel hosting this is standard and cannot easily be changed. Mitigations: 1. Ensure all email passwords are unique and strong (minimum 16 characters) 2. Enable HTTPS-only access to webmail (enforce TLS for all

mail protocols) 3. Use a dedicated email provider (Google Workspace, Microsoft 365) and point MX records there — this separates web and mail infrastructure

FINDING-006 — Autodiscover and Autoconfig Services Leaking Email Infrastructure Details

Severity: MEDIUM | **CVSS 3.1 Base Score: 5.3** (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

Description: Both `autodiscover.troandigital.net` and `autoconfig.troandigital.net` resolve publicly. These services return XML files that describe the email server configuration (hostnames, ports, protocol versions) to email clients like Outlook and Thunderbird. While designed for legitimate client configuration, they provide attackers with a detailed map of the email infrastructure without authentication.

Evidence:

```
DNS A autodiscover.troandigital.net → 63.250.38.177
DNS A autoconfig.troandigital.net → 63.250.38.177

Standard autodiscover response reveals:
- Mail server hostname and port
- Authentication methods supported
- Protocol versions (IMAP, POP3, SMTP)
```

Risk: - Targeted attack planning using disclosed server details - Enumeration of authentication mechanisms to target - Confirmation of infrastructure for credential-stuffing campaigns

Remediation: These are standard cPanel services and cannot easily be removed on shared hosting. They are a low-priority risk. Mitigate by: 1. Ensuring mail protocols enforce TLS (reject plaintext connections) 2. Enabling brute-force protection in cPanel → Security → cPHulk

FINDING-007 — FTP Server on Separate IP Not Protected by Primary Domain's SPF

Severity: LOW | **CVSS 3.1 Base Score: 3.7** (AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N)

Description: The FTP subdomain (`ftp.troandigital.net`) resolves to a different IP address (`63.250.38.141` / `premium314-1.web-hosting.com`) from the main server. While `63.250.38.141` is included in the SPF record (`+ip4:63.250.38.141`), the FTP service itself operates on port 21 which transmits credentials in cleartext if plain FTP (not FTPS) is used. The separation also means this host may have a different security posture from the primary server.

Evidence:

```
DNS A ftp.troandigital.net → 63.250.38.141 (≠ primary 63.250.38.177)
PTR 63.250.38.141 → premium314-1.web-hosting.com
SPF includes +ip4:63.250.38.141
```

Risk: - FTP credentials intercepted in transit if plain FTP used (no TLS) - Credential reuse: FTP password may match cPanel/SSH password - Different patch level on the separate IP

Remediation: 1. Use **FTPS (FTP over TLS)** exclusively — disable plain FTP in cPanel → FTP Accounts → Configure FTP Client (enforce TLS) 2. Consider migrating file transfers to **SFTP** (over SSH port 22) which encrypts both credentials and data 3. Use a dedicated, unique FTP password 4. Check the deploy workflow (`.github/workflows/deploy.yml`) uses FTPS — it does per review, which is correct

FINDING-008 — No IPv6 (AAAA) Records Configured

Severity: LOW | **CVSS 3.1 Base Score: 2.0** (AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:L)

Description: The domain has no IPv6 AAAA records configured. While not a direct security vulnerability, it means the site is inaccessible to IPv6-only clients and does not benefit from IPv6's larger address space (which makes scanning

somewhat harder). As the internet transitions to IPv6, this also creates a potential future gap if Namecheap assigns an IPv6 address that is not properly secured.

Evidence:

```
DNS AAAA troandigital.net → (NoAnswer)
```

Remediation: Low priority. If Namecheap assigns IPv6 addresses to the hosting account, ensure AAAA records are added and all security controls apply equally to IPv6.

FINDING-009 — DKIM Configured with Single Selector Only (No Rotation)

Severity: INFO | **CVSS 3.1 Base Score:** 0.0

Description: DKIM is properly configured (default._domainkey.troandigital.net with an RSA public key), which is positive. However, only a single selector (default) is present. Best practice is to use multiple selectors and rotate keys periodically. If the private DKIM key is ever compromised, there is no rotation mechanism in place. Additionally, the public key is exposed in DNS (as designed), allowing offline cryptographic analysis.

Evidence:

```
DNS TXT default._domainkey.troandigital.net:
"v=DKIM1; k=rsa; p=MIIBIjANBgkqhkiG9w0BAQEF..." (RSA public key, ~2048-bit)
```

Remediation: 1. Verify the key length is 2048-bit (cPanel default should be — confirm in cPanel → Email → Authentication) 2. Consider adding a second selector for rotation purposes 3. Plan annual DKIM key rotation — cPanel allows regenerating the key

5. Risk Rating Summary

Finding	Severity	CVSS	Ease of Exploit	Immediate Action
DMARC p=none — no enforcement	HIGH	7.5	Easy (any mail server)	Yes
SPF ~all SoftFail	HIGH	7.5	Easy (combined with above)	Yes
cPanel + WHM exposed publicly	HIGH	7.3	Medium (requires credentials)	Yes
WebDisk exposed publicly	MEDIUM	6.5	Medium	Review
Mail + web on same IP	MEDIUM	5.9	Hard (requires prior compromise)	Monitor
Autodiscover/Autoconfig info leak	MEDIUM	5.3	Easy (passive)	Low priority
FTP on separate IP / plaintext risk	LOW	3.7	Medium	Verify FTPS
No IPv6 AAAA records	LOW	2.0	N/A	Low priority
Single DKIM selector	INFO	0.0	N/A	Best practice

6. Strategic Recommendations

Immediate (within 48 hours)

- 1. **Fix DMARC enforcement** — change p=none to p=quarantine today. This is the single highest-impact, lowest-effort fix available. It takes 30 seconds in your DNS panel.
- 2. **Fix SPF qualifier** — change ~all to -all . One character change, DNS TTL propagation is the only delay.

3. **Enable 2FA on cPanel** — log into cPanel → Security → Two-Factor Authentication. This dramatically reduces the risk from credential theft against the admin panels.

Short-term (within 2 weeks)

1. **Audit admin panel access** — check cPanel's access logs. Consider restricting panel access to specific IPs if you work from a fixed location.
2. **Verify FTPS is enforced** on FTP connections — your GitHub Actions deploy already uses FTPS correctly. Ensure no one is using plain FTP for manual transfers.
3. **Review all cPanel email accounts** — delete unused accounts, rotate passwords for active ones, ensure all use strong unique passwords.

Medium-term (within 1 month)

1. **Consider dedicated email hosting** (Google Workspace / Microsoft 365) — separates mail from web infrastructure and provides much stronger anti-spoofing posture.
2. **Disable WebDisk** if not actively used — fewer exposed services = smaller attack surface.
3. **Run a full local pentest** using the orchestrator from your own machine or a VPS — this will add HTTP-level findings (server version, security headers, TLS config, web application vulnerabilities) that couldn't be reached from the sandbox.

7. Conclusion & Next Steps

troandigital.net is hosted on a standard shared cPanel platform with a **manageable but real attack surface**. The most urgent risks are at the **email security layer** — the DMARC and SPF configuration makes the domain trivially spoofable today. An attacker who wanted to impersonate your business could do so right now with a free email server.

The admin panel exposure is the second priority: cPanel and WHM are accessible to the entire internet. Without 2FA and strong credentials, these are one brute-force campaign away from a full account takeover.

The good news: **both top priorities are fixable in under 10 minutes** with DNS record edits and a cPanel settings toggle.

Next Steps for Full Assessment

To complete the HTTP-layer and exploitation phases (security headers, TLS version, web application vulnerabilities, CMS identification, authenticated brute-force, path traversal), run the orchestrator from a local machine or VPS where outbound TCP is unrestricted:

```
# On your local machine or a DigitalOcean/AWS VPS:
git clone https://github.com/rotimijasa/helloworld
cd helloworld
pip install -r pentest_orchestrator/requirements.txt
export ANTHROPIC_API_KEY=sk-ant-YOUR_KEY_HERE
python -m pentest_orchestrator.main --config pentest_orchestrator/engagement_troandigital.json
```

The orchestrator will then execute all five phases with full TCP access, producing a complete report covering web application vulnerabilities, TLS configuration, open port verification, and (if approved) exploitation PoCs.

Report generated by the Agentic Pentesting Orchestrator — TRO-2026-001 Engagement authorized by rotimijasa@gmail.com on 2026-05-29 CONFIDENTIAL — For authorized personnel only